CYBER DEFENSE CAPSTONE / PHASE 4B

Incident Response Plan & Procedures

Sam Miller | Team Lead

Operations Watch Commander / Incident Response Manager (IRM)

Academic coursework using Cyber Tree Systems, a fictional case-study organization. This public copy removes the assignment memo, other team members' names, and the individual AI-use disclosure page.

The plan reflects revisions after a Phase 4A rehearsal and team review, and was prepared for a later tabletop exercise.

CYBER TREE SYSTEMS

Incident Response Plan

Version 1.0.0

Reformat: November 14, 2025

Incident Response 3

1.0 Executive Sponsorship and Governance 3

2.0 Purpose 4

3.0 Scope & Objectives 5

4.0 Roles & Responsibilities 5

5.0 Cyber Insurance 8

6.0 Procedure 9

7.0 Classification & Severity Matrix 13

8.0 Post-Incident Evaluation Process 14

9.0 Integration with Business Continuity Plan & Disaster Recovery Plan 16

10.0 Planning, Testing, Training, & Exercises 17

11.0 Version Control & Continuous Improvement 20

12.0 Forms 21

Appendices – Incident Response Playbooks 22

Appendix A – Phishing Playbook 22

Appendix B – Ransomware Playbook 23

Appendix C – Insider Threat Playbook 26

Appendix D – DDoS Playbook 27

Appendix E – Generic/Emerging Threat Playbook 28

Appendix F – Forms Templates 29

LLM and Artificial Intelligence Tool Usage Statement: 31

Incident Response

1.0 Executive Sponsorship and Governance

1.1 Statement of Purpose

The purpose of this policy section is to formally document the endorsement and support at the executive level and follow the oversight structure for the Cyber Tree Systems (CTS) Incident Response Plan (IRP). It is the responsibility of the executive leadership to ensure that the IRP has the proper funding, authority, and oversight to remain effective across all departments within Cyber Tree Systems.

This section aligns with CTS's Enterprise Information Security Policy. It defines the ownership and accountability of the Chief Information Officer (CIO), Chief Information Security Officer (CISO), and Chief Executive Officer (CEO) for the continuous operation and enforcement of the IRP.

1.2 Executive Endorsement

The following Incident Response Plan is aligned with CTS's organizational mission objectives and compliance with federal and state regulations.

The following positions show the executive sponsors of this plan:

Title	Responsibility
Chief Executive Officer (CEO)	Provides corporate oversight, strategic, direction, and ensures organizational support for the IRP.
Chief information Officer (CIO)	Approves and enforces technical implementation of the IRP within all IT operations across CTS.
Chief Information Security Officer (CISO)	Ensure that the following plans align with the CTS Enterprise Information Security Policy and ensure that they are followed through.

1.3 Ownership & Oversight

The Incident Response Manager (IRM), under the supervision of the CISO and CIO, holds operational responsibility for maintaining, updating, and executing the IRP. The IRM will uphold operational responsibility for maintaining, updating, and executing the IRP.

The IRM will do the following:

1. Collaborate with IRP reviews and revisions, collaborating closely with executive sponsors to ensure continued relevance and compliance.
2. Document and report incident response metrics, such as time-to-response and time-to-recovery, during quarterly reviews.
3. Ensure appropriate staffing, funding, and tools are available for effective incident response operations.
4. Facilitates communication between the Computer Security Incident Response Team (CSIRT), executive management, and legal representatives.
5. Maintains a secure record of all IRP versions, revisions, and meeting summaries.

1.4 Governance Framework

The following chart outlines who is responsible for major oversight activities and how often they occur:

Governance	Oversight	Frequency	Deliverable
Plan Review & Approve	CIO/CISO	Annual	Signed IRP Revision
Resources and Budget Support	CEO/CFO	As Needed	Budget Approval Memo
Legal & Regulation Compliance	Legal Counsel	Semi-Annual	Compliance Report
Business Continuity / DRP Integration	CIO/CFO	Semi-Annual	Review Checklist
Internal Audit and Quality Review	InfoSec/Audit Team	Annual	Audit report

1.5 Authority

The Authority to establish, enforce, and update this plan is the responsibility of the Chief Information Officer (CIO) and Chief Information Security Officer (CISO). The incident Response Manager (IRM) coordinates all operational aspects of plan execution and documentation.

Any failure to comply with this governance structure may result in disciplinary action that is consistent with CTS's Enterprise Information Security Policy.

2.0 Purpose

The purpose of this Incident Response Plan (IRP) is to establish a standardized framework for identifying, responding to, containing, and recovering from cybersecurity incidents that threaten the confidentiality, integrity, or availability of Cyber Tree Systems (CTS) information systems and data assets. This plan ensures that all incidents are overseen in a coordinated, efficient, and timely manner to minimize operational impact, reduce financial losses, and maintain stakeholder trust. It also supports compliance with applicable regulatory and contractual obligations.

The IRP aligns with CTS's Enterprise Information Security Policy and supports the organization's overall mission by promoting operational resilience, safeguarding business continuity, and ensuring that security incidents are properly documented, communicated, and remediated in accordance with established governance.

3.0 Scope & Objectives

This plan applies to all CTS information systems, personnel, and third-party entities that access or manage organizational data or technology resources. The scope encompasses the detection, reporting, triage, containment, eradication, recovery, and post-incident review of all cybersecurity events that could affect CTS operations, reputation, or regulatory compliance.

Objectives:
The primary objectives of this plan are to:

1. Establish clear roles, responsibilities, and communication pathways for responding to cybersecurity incidents.
2. Ensure rapid identification, containment, and mitigation of threats to prevent escalation or recurrence.
3. Protect organizational assets and sensitive information from unauthorized access, use, or disclosure.
4. Facilitate consistent documentation, reporting, and analysis of all incidents to support compliance and audit requirements.
5. Integrate lessons learned from incidents into continuous improvement processes, policies, and employee training.
6. Support coordinated engagement with law enforcement, insurers, regulators, and external partners as required.

By achieving these objectives, CTS ensures an initiative-taking and resilient cybersecurity posture that supports operational continuity and stakeholder confidence.

4.0 Roles & Responsibilities

The effectiveness of the CTS Incident Response Team (CSIRT) depends on the participation of designated personnel who represent key organizational functions. During an incident, it may not always be possible for the primary role holders to participate directly; therefore, **authorized representatives** may fulfill these duties on behalf of their respective offices. Each role ensures that decisions made during incident response align with the interests and responsibilities of their department and the organization.

4.1 Operations Watch Commander / Incident Response Manager (IRM) – Sam Miller

The **Operations Watch Commander** serves as the **Incident Response Manager (IRM)** and provides leadership and direction during the earliest phases of incident response.

Primary Duties:

- Provides immediate leadership and coordination when an incident is detected.
- Directs containment and communication efforts until formal CSIRT procedures are activated.
- Coordinates with the CISO, CIO, and other representatives to determine response priorities.
- May transfer leadership to another designated authority once the incident response plan is fully in effect.
- Ensure documentation and communication flow between response participants.

4.2 Chief Information Security Officer (CISO) –

Primary Duties:

- Represents the interests of the Information Security function.
- Provides technical direction to the CSIRT during containment, eradication, and recovery.
- Brokers' communication between the CISO's staff and other departments involved in the response.
- Ensure incident response actions align with organizational security standards and policies.
- Reviews and approves post-incident recommendations for process or control improvements.

4.3 Chief Information Officer (CIO) –

Primary Duties:

- Represents of the interests of the CIO and IT Operations.
- Ensures timely coordination between technical staff supporting system recovery and network operations.
- Brokers communication between IT infrastructure teams and the CSIRT.
- Authorizes technical or operational actions required to contain or recover from an incident.
- Ensures that service restoration follows established change management procedures.

4.4 Corporate Chief Legal Counsel (CLC) –
Primary Duties:

- Represents the corporation's legal and regulatory interests throughout the incident lifecycle.
- Advises the CSIRT on compliance, data breach notification, and evidence managing.
- Serves as the primary conduit to the Chief Executive Officer (CEO) and the Board of Directors.
- Coordinates with law enforcement and external counsel when appropriate.
- Reviews post-incident documentation to assess legal exposure and ensure compliance.

4.5 Corporate Communications Officer (CCO) –

The **representative from the office of the Corporate Communications Officer (CCO)** ensures all communication activities comply with organizational policy.
Primary Duties:

- Coordinates internal and external communication related to the incident.
- Ensures that public statements, media releases, and customer communications are accurate and approved.
- Works closely with the CLC to ensure communication aligns with legal and regulatory obligations.
- Maintains a record of all communication activities related to the incident.
- Evaluates post-incident communications for clarity, effectiveness, and compliance.

4.6 Chief Financial Officer (CFO) –

The **representative from the office of the Chief Financial Officer (CFO)** manages financial and business impact considerations.
Primary Duties:

- Represents the interests of the CFO during incident assessment and recovery.
- Tracks direct and indirect financial impacts of incident response activities.
- Brokers communication between financial operations and the CSIRT.
- Assists in evaluating resource needs, potential insurance claims, and recovery costs.
- Contributes to post-incident analysis regarding financial exposure or business disruption.

4.7 Observers / Support Participants

Observers or support participants may attend incident response meetings or exercises to aid or gain familiarity with response procedures.

Primary Duties:

- Assist the CSIRT with documentation, coordination, and adherence to procedures.
- Engage in the response process as assigned by the IRM.
- Support the proper use and reference of the Incident Response Plan during live incidents or exercises.
- If more than six active team members are present, additional participants will serve as observers or reserve members.
- If fewer than six active members are available, roles will be staffed in the order listed above.

5.0 Cyber Insurance

The organization maintains a comprehensive cyber insurance policy to mitigate financial and legal impacts resulting from cyber incidents such as data breaches, ransomware, or system outages. Upon confirmation of an incident, the Chief Legal Counsel will immediately notify the insurer in accordance with policy requirements to initiate coverage and response support.

The insurance provider may supply specialized services, including digital forensics, legal and regulatory guidance, public relations assistance, and ransomware negotiation support. Covered expenses may include data recovery, business interruption losses, regulatory fines, and third-party claims.

All actions, communications, and incurred costs must be documented to support insurance claims and compliance reporting. Following the incident, the Legal and IT teams will review policy performance and update coverage as needed to ensure continued protection against evolving cyber threats.

5.1 Legal & Regulatory Compliance

All incident response activities must adhere to applicable cybersecurity and data protection laws, including HIPAA, GDPR, and relevant state privacy regulations. The Chief Legal Counsel ensures that all actions—such as reporting, documentation, and communication—meet mandatory legal and regulatory standards. In the event of a data breach involving protected health information (PHI) or personally identifiable information (PII), the organization must follow HIPAA breach notification requirements and any state-specific reporting obligations.

Evidence and communications should be properly documented to maintain compliance, transparency, and legal defensibility during audits or investigations.

5.2 Communications Protocols (Legal Notices)

In the event of a confirmed or suspected cyber incident, all external communications must be coordinated through the Chief Legal Counsel to ensure accuracy and compliance with applicable laws. The Legal Department will determine reporting obligations under HIPAA, GDPR, and state data breach notification laws, including timelines for notifying affected individuals, regulators, and business partners.

No employee or department may disclose information about the incident without legal authorization. Official breach notifications and legal notices must be reviewed and approved by the Chief Legal Counsel before release. All internal communications and external—should be documented and preserved as part of the incident record to support compliance, insurance claims, and potential legal proceedings.

6.0 Procedure

6.1 Detection and Reporting

Cyber Tree Systems (CTS) maintains layered monitoring and detection capabilities designed to identify potential security incidents in real time. The organization leverages integrated security technologies, centralized analysis, and defined escalation procedures to ensure timely detection and response.

Monitoring and Detection Capabilities

CTS employs multiple complementary systems to provide continuous visibility across network, endpoint, and application layers:

- **Intrusion Detection and Prevention Systems (IDS/IPS):** Monitor inbound and outbound network traffic for malicious signatures, anomalies, and intrusion attempts. Confirmed detections are forwarded automatically to the SIEM for correlation and enrichment.
- **Security Information and Event Management (SIEM):** Serves as the central aggregation and analytics platform. It ingests logs and alerts from the IDS/IPS, endpoint detection tools, firewalls, servers, cloud workloads, and business-critical applications. The SIEM applies correlation rules, baselines, and threat intelligence to identify patterns requiring investigation.
- **Endpoint Detection and Response (EDR):** Provides continuous endpoint telemetry, behavioral monitoring, and automated containment actions on workstations and servers. High-severity EDR alerts are also ingested into the SIEM.

- **Threat Intelligence Feeds:** Third-party and commercial threat intelligence services provide indicators of compromise (IOCs) such as malicious IPs, domains, and file hashes. These are integrated into SIEM and IDS/IPS rulesets to improve detection accuracy and contextual awareness.

Alert Generation and Logging

All integrated monitoring systems feed into the SIEM, which acts as the **sole source of truth** for security event management.

- When a system or network anomaly meets defined alert thresholds, the SIEM automatically generates an **incident alert**, assigns a **severity level**, and logs it in the **Incident Tracking System (ITS)** as a new ticket.
- Each ticket includes the source, timestamp, asset affected, and correlation details.
- **Low-severity alerts** are logged and reviewed during trend analysis.
- **Medium- and high-severity alerts** are immediately routed to the **Information Security (InfoSec)** team for triage.

Triage and Escalation Workflow

1. **Initial Review:** InfoSec analysts review the alert in the SIEM, validate it against correlated data and contextual threat intelligence, and determine whether it represents a true positive incident.
2. **Escalation Criteria:**
    a. Alerts confirmed as false positives are closed and retained for tuning analysis.
    b. Alerts validated as legitimate threats are escalated according to the **Severity Matrix (Section 7.2)**.
3. **Notification:**
    a. For medium and high-severity incidents, the **Incident Response Manager (IRM)** is automatically notified.
    b. The IRM coordinates with the **CISO** and **CIO** to determine whether to activate the **Cyber Security Incident Response Team (CSIRT)**.
4. **Ticket Tracking:**
    a. All confirmed incidents are tracked in the ITS throughout their lifecycle, from detection through closure.
    b. Actions taken, communications, and timestamps must be recorded within the same ticket for audit and compliance traceability.

Human and Third-Party Reporting

CTS employees and third-party service providers may also identify, and report suspected incidents not automatically detected by monitoring tools.

- Employees must report potential security issues to the **CTS Help Desk** via phone or ticket submission.
- The Help Desk will open an ITS ticket including:
    - Description of the suspected incident
    - Time and date of discovery
    - Systems or data affected.
    - Names of employees or contractors involved or impacted.
- The Help Desk escalates all security-related tickets directly to the InfoSec team.

If an incident involves legal, regulatory, or contractual implications, the **Corporate Chief Legal Counsel (CLC)** must be notified immediately by the **CISO** or their designee. All such notifications and subsequent actions will be logged within the incident record.

6.2 Confirmation, Triage, and Classification

Upon receipt of an alert or report, InfoSec analysts will review available SIEM data, logs, and supporting evidence to verify the incident. All alerts and anomalous network activity must be evaluated within operational context. Analysts should compare detected events against established baselines and known operational patterns (e.g., scheduled backups, update windows) to determine whether the activity is normal or indicative of a potential incident. This contextualization step is a required part of anomaly-based triage and ensures that incident responders focus escalation efforts on genuinely suspicious or abnormal events. Once confirmed, the incident is categorized according to severity as defined in section 7.2 of this document.

Any incident rated **SEV 1, 2, or 3 must be** immediately escalated as described in **section 6.3**. The **Incident Response Manager (IRM)** must be contacted by both **phone and email**, along with notification to senior management, if SEV 2 or higher.

For incidents rated **SEV 2 or higher**, the **IRM** will convene a preliminary coordination call that includes representatives from the offices of the **Chief Information Security Officer (CISO)** and **Chief Information Officer (CIO)**.

If customer data, regulatory exposure, or potential public communication is involved, representatives from the **Corporate Chief Legal Counsel (CLC)** and **Corporate Communications Officer (CCO)** will also be included.

The **Chief Financial Officer (CFO)** or their designated representative will be informed about incidents that are SEV 2 or higher or if financial exposure or operational costs are anticipated as part of the incident.

6.3. Incident Response Actions

Once an incident has been categorized, the InfoSec team or **Cybersecurity Incident Response Team (CSIRT)** will be activated as needed. The **Incident Response Manager** will assume command of response coordination. The **IRM** ensures the **CSIRT** remains aligned with executive expectations and maintains communication with the **CIO**, **CLC**, and other affected departments. The team will follow the standard NIST response phases:

a. Containment

CSIRT will isolate affected systems to prevent further spread or damage. Containment may include disconnecting systems from the network, disabling accounts, or applying temporary firewall rules.

- **Mission-critical systems:** The system will be bit-copied for evidence preservation and restored to service as soon as containment and safety are verified.
- **Non-critical systems:** These will remain offline until forensic investigation is complete and vulnerabilities are remediated.

b. Eradication, Post-Incident Confirmation, and Recovery

SIRT will identify and eliminate the root cause of the incident, such as malware, unauthorized access, or configuration errors. Systems will then be cleaned, patched, and returned to service after verification of integrity.

Affected systems will be carefully monitored for a one-month period following the incident to detect any recurrence of the incident. The SIRT will confirm that the appropriate long-term measures have been taken to prevent the recurrence of the incident.

Where required, systems may be restored from secure backups to ensure operational continuity.

6.4. Documentation and Recordkeeping

A file will be maintained for every confirmed incident, containing:

- Incident detection source
- Logs, screenshots, and forensic data collected.
- SIRT communications and actions taken.
- Incident category and resolution
- Post-incident review and recommendations

All incident records will be stored securely in accordance with CTS data retention and confidentiality policies.

The **CISO** is responsible for maintaining all incident documentation and ensuring that records are available for internal audit and compliance review. Copies of incident summaries may be provided to the **CIO**, **CLC**, and **CFO** as appropriate for oversight, risk, and fiscal impact assessment.

7.0 Classification & Severity Matrix

7.1 Purpose and alignment

The following are the incident severities and their respective impacts on CTS systems, services, and operations as a whole:

- SEV 1 — Complete loss of service or severe/widespread breach.
- SEV 2 — Downtime or compromise of core/critical servers or network infrastructure.
- SEV 3 — Potential/actual downtime to non-critical or low-priority workstation, server, or app.
- SEV 4 — Minor service disruption with no customer impact.

Detection & hand-off

Most incidents originate from SIEM alerts and employee reports. Alerts are auto-prioritized by severity and asset class; medium/high severity incidents go straight to InfoSec and automatically notify the Incident Response Manager (IRM).

Triage

The InfoSec team confirms, classifies, and escalates by the matrix below. Incidents with SEV 1–3 require immediate escalation to the InfoSec team (phone & email). Senior management notification thresholds begin at SEV 2.

Regulatory and IDS tie-in

Suspected intrusions must be reported promptly and can trigger the IR plan; intrusions with financial or customer data loss must be reported to executive leadership (CFO / CLC) per policy timelines.

7.2 Matrix

SEV	Business Impact (examples)	Initial Actions & Escalation
SEV 1	Complete loss of a major service (e.g., corporate email, identity, ERP); confirmed data breach; ransomware with encryption in progress; facility-/cloud-wide outage.	IRM + CISO assume command; convene CSIRT; notify CIO/CLC/CCO (and CFO if material); initiate containment on mission-critical systems with evidence preservation and a rapid restoration path.
SEV 2	Downtime/compromise of core servers or network (e.g., AD/DCs, perimeter firewalls, core switches, shared databases); high-risk exfiltration indicators.	Immediate escalation to InfoSec; IRM convenes coordination call with CISO/CIO; add CLC/CCO if customer/regulatory exposure is likely.
SEV 3	Potential/actual downtime of non-critical servers/apps; limited malware infection; configuration error with contained blast radius.	Escalate to InfoSec by phone and email; IRM notified; proceed with standard containment, verification, and monitoring.
SEV 4	Minor disruption (single workstation, nuisance malware, low-impact policy violation) with no customer impact.	Help Desk ticket and local admin remediation; escalate if conditions worsen or new indicators emerge.

Notes

• "Mission-critical" systems may be bit-copied for evidence and restored quickly once safe to do so; non-critical systems can remain offline until full forensics and remediation are complete.
• When IDS or other sensors detect abnormal activity, the IR plan is initiated, and logs are retained per the data-retention policy.

8.0 Post-Incident Evaluation Process

Following containment and recovery, the Cyber Security Incident Response Team (CSIRT) will conduct a structured post-incident evaluation to assess response effectiveness, identify improvement areas, and ensure all documentation and reporting requirements are complete. This process applies to all confirmed incidents and to planned exercises simulating incident conditions.

8.1 Hotwash Session

Immediately after incident closure or exercise completion, the **Incident Response Manager (IRM)** will convene a **hotwash session** involving all active participants.
The purpose of the hotwash is to capture real-time feedback while details are fresh, focusing on:

- What actions went well and why?
- What obstacles or delays occurred
- What procedures, tools, or communications need improvement

Observations will be recorded in preliminary notes by the IRM or assigned recorder and submitted to the **Chief Information Security Officer (CISO)** for inclusion in the After-Action Report.

8.2 After-Action Report (AAR)

Each participant in the Incident Response event will create an **After-Action Report (AAR)**.
Each AAR will include:

- **Overview**
- Date, time, and duration of the exercise
- Exercise type and scope (e.g., tabletop, functional, full-scale)
- Scenario summary and general context
- **Goals and Objectives**
- Stated goals of the exercise (what it aimed to achieve)
- Specific, measurable objectives established before the exercise
- Alignment of objectives with organizational plans or policies
- **Event Analysis**
- Chronological or thematic summary of what occurred during the exercise
- Key decisions made and their outcomes
- Deviations from expected procedures or plans and why they occurred
- Notable successes and challenges observed
- **Performance Analysis**
- Evaluation of performance for each **critical task or capability**
- Identification of tasks that were successfully executed
- Tasks that were partially met or unmet, and the reasons why
- Observations on communication, coordination, and decision-making
- Assessment of how policies, tools, and resources supported performance
- **Summary**
- Major strengths demonstrated during the exercise

- Key areas for improvement
- Overall assessment of readiness and response capability
- **Recommendations**
- Specific, actionable steps to address identified gaps or weaknesses
- Responsible parties or departments for each recommendation
- Suggested timelines or priorities for implementation
- Opportunities for further training, policy updates, or procedural changes

8.3 Improvement and Corrective Actions

Based on AAR findings, **CISO** and **IRM** will coordinate with responsible departments to implement corrective actions, which may include:

- Policy or procedure revisions
- Enhanced logging, detection, or alerting mechanisms.
- Staff training or awareness updates
- Control or technological improvements.

The **CIO** and **IRM** will track completion of assigned remediation tasks. Progress will be made during quarterly InfoSec governance meetings to ensure accountability and closure.

8.4 Reporting and Notifications

If legal, regulatory, or contractual reporting is required, the **Chief Corporate Legal Counsel (CLC)** and **Corporate Communications Officer (CCO)** will verify completion of all external notifications.
The **Chief Financial Officer (CFO)** will assess fiscal impact and recovery costs as documented in the AAR.

Once all evaluations and improvements are complete, the **CISO** will formally close the incident record and archive the final report for audit, compliance, and trend analysis.

9.0 Integration with Business Continuity Plan & Disaster Recovery Plan

9.1 Why integration is important.

IRP, BCP, and DRP must be coordinated so that response actions, restoration priorities, and approvals stay aligned. This plan requires periodic joint review to ensure that handoffs, objectives, teams, and communications are synchronized.

9.2 When IR transitions to BCP/DRP

- IR-only scenarios (SEV 3–4; some SEV 2): Security containment/eradication with limited operational disruption. Restoration proceeds under IR change control and standard IT procedures.
- IR + BCP/DRP scenarios (SEV 1; many SEV 2): Incidents that cripple essential services, create sustained downtime, or threaten facilities. In these cases, DRP objectives raise critical computing capability rapidly with the latest data using alternative sites or cloud recovery if needed.

Triggers to invoke DRP/BCP include:

- Complete loss of a major service.
- Core network collapse or widespread outage.
- Primary data-center/facility unavailability or safety issues.
- Ransomware requires mass rebuilding or recovery from backups.
- Material customer, regulatory, or fiscal impact that requires expedited restoration.

9.3 Roles and governance across IRP and DRP

- Incident Response Manager (IRM): Leads early phases and coordinates with CISO/CIO; may transfer leadership as DRP fully activates.
- CISO / CIO: Own technical direction and operational coordination; ensure actions follow security standards and change control.
- CLC / CCO / CFO: Added for legal, communications, and fiscal impact on SEV 2+ incidents and all DR activations.
- Governance: Require periodic IRP↔BCP/DRP integration reviews and audits to keep plans synchronized.

9.4 Testing & maintenance

- IRP: Test bi-annually; train/exercise quarterly; perform a formal plan review annually and after every major incident.
- Integrated improvements: Use version control and continuous improvement to ingest findings from post-incident reviews, exercises, audits, and new threat intelligence; CIO/CISO ensure consistency with continuity and compliance obligations.

10.0 Planning, Testing, Training, & Exercises

CTS maintains a structured program for training, testing, and exercises to ensure readiness, validate the effectiveness of this plan, and promote continuous improvement in the organization's ability to detect, respond to, and recover from security incidents.

10.1 Training

The **Chief Information Security Officer (CISO)** oversees all incident response training activities, ensuring that personnel understand their roles and responsibilities under this plan.

a. General Employee Training:
All CTS employees receive annual security awareness training, which includes recognizing and reporting potential security incidents through the Help Desk or incident ticketing system.

b. Specialized CSIRT Training:
Members of the **Cybersecurity Incident Response Team (CSIRT)**, along with the **Incident Response Manager (IRM)**, receive specialized, role-based training at least annually or upon major updates. This training covers response procedures, escalation paths, communications, evidence managing, and use of security tools (SIEM, IDS, and ITS).

c. Documentation:
The IRM maintains training attendance records, completion logs, and materials as part of compliance and readiness documentation.

10.2 Testing of Tools and Procedures

Testing validates the effectiveness of CTS's detection, alerting, and escalation mechanisms.

a. Scope:
Tests include validation of the Intrusion Detection System (IDS), Security Information and Event Management (SIEM) correlation rules, ticket creation and escalation processes, and communication channels between response roles.

b. Frequency:

- **Quarterly:** Functional tests of alerting and escalation mechanisms.
- **Semi-Annually:** Full workflow validation from detection through documentation.

c. Responsibility:
Testing is coordinated by the **CISO** and executed by the **InfoSec** and **IT Operations** teams, with results reviewed by the **CIO** and **IRM**. Findings are logged in the Incident Tracking System (ITS) and discussed during quarterly InfoSec governance meetings.

10.3 Tabletop Exercises

The **Incident Response Manager (IRM)** conducts **tabletop exercises (TTX)** to simulate realistic cyber incidents in a no-fault, discussion-based environment.

a. Frequency:
At least one enterprise-wide tabletop exercise will be held annually. Additional focused exercises may be conducted following significant incidents, major infrastructure changes, or policy updates.

b. Participation:
Exercises will include representatives from Information Security, IT Operations, Legal (CLC), Communications (CCO), and Finance (CFO). External partners or observers may be included as appropriate.

c. Objectives:

- Assess coordination, communication, and decision-making effectiveness.
- Validate procedures outlined in this plan.
- Identify weaknesses or ambiguities in response processes.

d. Evaluation:
Each exercise concludes with a **hotwash** and a documented **After-Action Report (AAR)** per Section 8.2. Recommended improvements are assigned to responsible parties and tracked to completion.

10.4 Continuous Improvement

Lessons learned from training, testing, and exercises will feed directly into plan revisions, process refinement, and staff development.

The **CISO** ensures that all improvement actions are documented, prioritized, and incorporated into the next scheduled plan review as outlined in **Section 12.0 (Version Control & Continuous Improvement).**

10.0 Review Schedule ((CIO)

The Incident Response Plan will be reviewed annually and following any major incident, organizational change, or technology update that could impact its effectiveness. Reviews will be coordinated by the Information Security Department and the Incident Response Manager (IRM) under the supervision of the CIO and CISO.

Additionally, a post-incident review will be conducted after every confirmed security incident or exercise to determine whether plan modifications are needed. Any approved revisions will be documented in the Version Control section, and all relevant personnel will be notified of updates.

This structured review cycle ensures that the IRP remains current, effective, and aligned with emerging threats, evolving compliance requirements, and business objectives of Cyber Tree Systems.

11.0 Version Control & Continuous Improvement

Response Manager (IRM) is responsible for maintaining version control of this plan and the playbooks associated with it. The plan must be reviewed annually, or immediately following any major incident, tabletop exercise (TTX), or organizational change. Each revision must include a version number, author, date of revision, and a brief description of the updates made. The CIO and CISO will review all proposed changes for required approval before the plan is rolled out. Any previous version of the plan will be archived for a minimum timeline of three years for reference and auditing purposes.

Continuous improvements will follow findings from the following:

- Post-incident reviews (Hotwashes), and lessons learned.
- Training exercises and simulations, such as TTX.
- Audit and compliance assessments.
- Changes in technology, regulations, or threat intelligence.

Procedures for Updates to the policy

- The IRM will collect feedback from the other departments involved in incident response after each exercise or rollout.
- Recommended revisions will be documented and presented to executive leadership during the next scheduled review cycle.
- Once the plan is approved, the updated plan will be distributed to all stakeholders and stored properly.
- Each distributed copy must display the current version number and effective date.

Governance and Responsibility

The CIO and CISO oversee the official approval of all revisions to ensure that they are consistent with corporate security policies, business continuity planning, and compliance requirements. The IRM coordinates this process and ensures that all documentation, including version history, meeting notes, and approvals, is retained adequately for audit purposes.

Revision History

Version	Date	Author	Summary of Change	Approved by
1.0	10/2025	Sam Miller	Initial creation of Version Control and Continuous Improvement section.	CIO / CISO
1.1	11/2025	Group 7	Edited IR plan to address the flow of	CIO/CISO

			the document, as well as chain of command. The Post-Incident Analysis has been updated to meet CTS requirements.	
1.2	11/2025	Group 7	Essay sections have been reorganized for better flow, and index was created.	CIO/CISO

12.0 Forms

13.1 Use of Forms

As the Corporate Communications Officer, I utilize these forms to maintain consistent and transparent communication during the incident response process. The Incident Declaration form serves as the trigger for initiating internal communication channels, ensuring leadership is promptly informed. The Incident Status Update form is used to provide timely updates to executives and management as added information becomes available. Upon resolution, the Incident Closure and End of Recovery form allows me to formally communicate the end of response efforts and prepare any external statements if necessary. The Incident Review form supports my role in documenting lessons learned and identifying communication improvements. Finally, the Incident Response Plan Addendum ensures that updates to communication strategies are reflected in future IR procedures, aligning messaging consistency with organizational objectives.

There are several ways to be utilized throughout the IR process:

Form	Use
• Incident declaration	Used to specify the details of the incident once determined critical by IS staff.
• Incident status update	Used to notify C-level and managerial staff of incident during the investigation.
• Incident closure and end of recovery	Used at the end of an investigation to officially disposition the case as “closed” and determine if the affected systems can be returned to service.
• Incident Review	Used at the end of the investigation to determine what process flows could be

	modified for efficiency and determine if legal recourse is necessary.
• Incident Response Plan Addendum to Attack Success End Case	Used to modify the IR plan according to investigation findings to prevent future occurrences.

Templates can be found in Appendix F (page 15 of this document)

Appendices – Incident Response Playbooks

Appendix A – Phishing Playbook

1. Scope & Objectives

- Applies to phishing and social-engineering emails or messages that attempt to steal credentials, deliver malware, or trick CTS employees into unauthorized actions.
- Objectives: detect and stop phishing quickly, remove malicious messages, protect accounts and data, and increase employee awareness through training and communication.

2. Roles & Escalation

- Incident Response Manager (IRM): Opens the case, assigns tasks, and manages coordination.
- InfoSec Team: Reviews and blocks malicious emails, updates filters, and monitors alerts.
- IT and CIO: Resets passwords, disables compromised accounts, and restores systems.
- Legal and Communications: Approve external notifications if sensitive data is exposed.
- Help Desk: Collects user reports and assists with password resets or device checks.

3. Detection

Common Signals

- Unusual sender addresses or spoofed domains.
- Requests for credentials or payment details.
- Attachments or links with suspicious file types.
- Multiple reports of similar emails from staff.

4. First Hour — Initial Containment & Triage

0–15 minutes (do now):

1. Open an incident record and collect sample messages, headers, and links.
2. Block sender domains, IPs, and URLs at the email gateway and DNS level.
3. Quarantine or delete matching emails from user inboxes.

15–60 minutes:

4. Identify any users who clicked links or entered data; reset passwords and revoke sessions.
5. Notify staff of the phishing attempt and remind them not to interact with the message.

5. Containment & Recovery

- Disable or reset affected accounts.
- Remove malware or rebuild affected systems if necessary.
- Verify system integrity and re-enable access only after validation.
- Share lessons learned and reminders through internal communications.

6. Post-Incident Actions

- Conduct a brief "hotwash" meeting to review actions taken.
- Update filters, training materials, and detection rules.
- Document the event for trend tracking and insurance purposes.

Appendix B – Ransomware Playbook

1. Scope & Objectives

- Applies to ransomware/destructive malware impacting CTS endpoints, servers, identity, network, SaaS, and cloud workloads.
- Objectives: stop spreading quickly, preserve evidence, restore critical services safely, meet legal/contractual obligations.

2. Roles & Escalation

- Incident Response Manager (IRM): leads playbook execution, owns timeline/bridge.
- CISO: containment/eradication authority; external security comms.
- CIO: restoration/DR activation and change control authority.
- Corporate Counsel (Legal) & Communications: notifications, regulators/law enforcement, insurance.
- Forensics: evidence, root cause, IOC development.
- IT/NetOps/Clouds: isolation, rebuilding, recovery orchestration.

Severity: Treat confirmed server encryption or multi-endpoint impact as SEV 1 (or high SEV 2) and invoke this playbook immediately.

3. Detection

Common Signals:

- Ransom notes; files with new extensions; mass renames/deletions; sudden app failures.
- EDR/SIEM alerts: shadow copy deletion (sysadmin/wbadmin), credential dumping, lateral movement (RDP/SMB/WinRE), suspicious PowerShell/LOLBins.
- Network: C2/TOR beacons; spikes in SMB errors; anomalous Kerberos or RDP logins.
- User reports of inaccessible files or ransom screens.

4. First Hour — Initial Containment & Triage

0–15 minutes (do now):

6. Open incident record and bridge; capture time, scope, affected assets, screenshots, ransom notes, and sample encrypted files.
7. Isolate suspected systems: EDR "isolate," disconnect NICs, disable switch ports, move to quarantine VLAN; revoke active VPN sessions.
8. Block spread: temporary ACLs to restrict SMB (445)/RDP (3389) in affected segments; push C2/TOR blocks; pause risky automation jobs.

15–60 minutes:

9. Expand containment to blast radius (adjacent subnets, shared credentials, same hypervisor/cluster).
10. Disable/rotate suspected accounts; force password resets; invalidate OAuth tokens/API keys.
11. Quarantine backups exposed to infected shares; verify integrity of offline/immutable copies.

5. Timelines & Continuity Thresholds

- Tier-1 services (Identity/AD, Core Network, Shared DBs, Email): target RTO ≤ 4 hours; if RTO > 4 hours or ≥30% Tier-1 nodes affected → activate DR.
- Tier-2 business apps: target RTO ≤ 24 hours; activate DR if >40% unavailable or Tier-1 dependencies require failover.
- RPO: restore from last known-good offline/immutable backups (Tier-1 ≤ 4 hours; Tier-2 ≤ 24 hours).

6. Containment Procedures — Isolate Affected Systems

- Network: quarantine VLAN; ACL deny east-west SMB/RDP; apply geolocation blocks; IDS/IPS signatures updated; shut down switch ports as needed.
- Host: EDR isolate; avoid power-off unless encryptor is active and isolation is impossible; collect quick triage (process list, connections, autoruns, PowerShell history).
- Identity: disable suspected users/service accounts; rotate privileged creds; plan staged KRBTGT resets if DC compromise suspected.
- Backups: write-protect/air-gap; suspend jobs targeting infected shares; verify immutability and access logs.

7. Eradication Procedures — Remove Threat Actors & Malware

- Identify malware family and persistence mechanisms (services, run keys, WMI, scheduled tasks, startup folders, cron/systemd).
- Hunt and remove IOCs at scale; patch vulnerable components; close initial access vector (phish account, exposed RDP/VPN, vulnerable services).
- Reimage systems where integrity is uncertain — mandatory for Tier-one servers; rebuild from gold images and reapply baselines.

8. Recovery Procedures — Restore Services Securely

- Use clean-room network to rebuild baselines; apply current patches and security baselines (hardening/CIS/ASR/AppLocker/WDAC as applicable).
- Restore prioritized services from offline/immutable backups; verify with checksums and malware scans before production attach.
- Rotate credentials, keys, and secrets (service accounts, API keys, SSO/OAuth, TLS certs); remove legacy trust paths.
- Phased return to production with enhanced monitoring for 7–14 days; validate integrity and performance after each wave.

Platform notes (tailor per CTS estate): AD first if impacted (verify GPOs, SYSVOL, consider staged KRBTGT resets); Linux servers rebuild from packages with configs from version control; DBs restore to isolated instance and run integrity checks; apps redeploy from trusted CI.

9. Legal & Compliance Touchpoints

- Preserve evidence (forensic images/snapshots) with chain of custody before rebuilding.
- Engage Corporate Counsel early: breach assessment, regulator/law-enforcement coordination, insurer engagement, contractual obligations.
- No ransom negotiation/payment without executive and legal approval; document all third-party interactions.

10. Communications

- Internal: incident bridge updates at agreed cadence; do/do not' guidance for employees (do not power off, disconnect from network, report anomalies).
- External: customer/partner notifications coordinated by Communications + Legal; sole source of truth for status statements.

11. Technical Checklists (Execution Aids)

Network Controls:

- Quarantine VLAN live; ACLs to block SMB (445)/RDP (3389) east-west; C2/TOR blocks deployed; IDS/IPS sigs pushed; switch/VPN revocations complete.

Endpoints/Servers:

- EDR isolation; persistence removed; reimage when in doubt; restore data from clean offline/immutable backups.

Identity/Access:

- Disable/rotate compromised accounts/keys; reset privileged creds; review GPOs/role assignments; remove legacy trusts.

Backups/Storage:

- Verify offline/immutable copies; test restorations in clean room; enforce MFA and role separation on backup consoles.

12. Post-Incident Guidance

- Service normalization and integrity verification complete; remove temporary controls as appropriate.
- Within three business days: post-incident review, timeline, impact, root cause, corrective actions with owners and due dates.
- Within ten business days: implement prioritized improvements (EDR policies, segmentation, PAM, backup immutability, phishing controls).
- Within 30 days: exercise revised procedures (tabletop or live test); updated IRP/BCP/DRP and training materials.

Appendix C – Insider Threat Playbook

1. **Scope**

   This playbook applies to all internal personnel, including full-time employees, contractors, interns, and vendors with system access, who may be implicated in a cybersecurity event.

2. **Roles and Responsibilities**

   Corporate Communications Officer (CCO)

   - Acts as the single point of contact for all internal and external communications regarding the insider incident.
   - Coordinates closely with the Incident Response Manager (IRM), Human Resources (HR), and Legal Counsel.
   - Ensures that no unauthorized personnel release information or comment on the case.
   - Prepares internal updates, executive briefings, and (if approved) external statements.

   Supporting Teams:

   HR: Manages employee relations, interviews, and potential disciplinary actions.

   Legal Counsel: Reviews of all statements for legal accuracy and compliance.

   IT/Security: Provides verified technical updates to inform communications.

3. **Communication Protocol**

   Initial Notification

   - Upon identification of a potential insider threat, the CCO is notified by the Incident Response Manager.
   - The CCO convenes a confidential meeting with HR and Legal to align approved language and disclosure levels.

Post-Incident Actions

- Participate in the post-incident review to identify improvements in insider threat detection and communication processes.
- Work with HR and IT to develop awareness messages or training campaigns to prevent similar incidents.
- Update this playbook and related IR communication policies through the Incident Response Plan Addendum process.

External Communication

- No external statement is released unless authorized by Legal Counsel and executive leadership.
- If the incident becomes public, the CCO will prepare a carefully worded media statement focusing on response actions rather than attribution.
- All media and customer inquiries are routed to the CCO.

Appendix D – DDoS Playbook

1. Scope & Objectives

- Applies to denial-of-service (DDoS) attacks that flood CTS public-facing services such as websites, VPN gateways, email servers, or cloud applications.
- Objectives: maintain service availability, mitigate traffic surges through filtering and provider support, protect data integrity, and restore normal network operations safely and quickly.

2. Roles & Escalation

- IRM: Opens the DDoS case, starts the response bridge, and coordinates updates.
- CIO: Implements filtering, rerouting, and communication with ISPs.
- CISO: Validates the attack type and provides guidance on mitigation steps.
- Legal and Communications: Prepare customer notices or statements if required.

3. Detection

Indicators of DDoS Activity:

- Sudden network slowdowns or outages.
- High CPU or bandwidth utilization on edge systems.
- Alerts from monitoring or external testing platforms.
- Spikes in identical traffic from many IP addresses.

4. First Hour – Initial Response

0–15 minutes:

1. Confirm the DDoS event and alert the Network Ops and InfoSec teams.
2. Capture traffic statistics and packet samples.
3. Activate DDoS mitigation services or filtering rules.

15–60 minutes:

4. Contact ISPs or cloud providers for upstream blocking or rerouting.
5. Apply temporary geo-blocking or rate limits to control the attack volume.

5. Containment & Recovery

- Maintain filtering until traffic normalizes.
- Restore services gradually and monitor performance.
- Verify that no secondary intrusions occurred during the event.

6. Post-Incident Actions

- Conduct a brief review meeting and document the response timeline.
- Update firewall, WAF, or CDN configurations.
- Plan a follow-up tabletop exercise to improve readiness.

Appendix E – Generic/Emerging Threat Playbook

1. Scope & Objectives

- Applies to new or unclassified cyber threats including zero-day exploits, supply-chain compromises, or combined attack types that do not fit existing playbooks.
- Objectives: identify the threat early, limit risk to CTS systems and partners, apply temporary controls until permanent fixes are available, and update procedures to prevent future incidents.

2. Roles & Escalation

- IRM: Opens the case, gathers the right specialists, and coordinates response efforts.
- Threat Intelligence / CSIRT: Collects information from vendors and security sources.
- CISO / CIO: Approves actions such as isolating or shutting down systems.
- Legal and Vendor Management: Coordinate with suppliers or partners when needed.

3. Detection

Common Indicators:

- Unusual or unexplained system behavior.
- New alerts that do not match known signatures.
- External warnings or advisories about new vulnerabilities.

4. First Hour – Initial Assessment & Containment

0–15 minutes:

1. Open an incident record and document all known details.
2. Collect logs, screenshots, and evidence from affected systems.
3. Apply temporary blocks or disable risky services if needed.

15–60 minutes:

4. Search vendors and government advisories for updates or fixes.
5. Engage vendors or third parties for investigation support.

5. Containment & Eradication

- Keep the affected systems isolated until root cause is known.
- Apply patches or remove malicious files.
- Rotate passwords, tokens, or keys that might have been exposed.

6. Recovery & Follow-Up

- Return systems to production after full testing and verification.
- Increase monitoring for several weeks after recovery.
- Hold a review meeting to discuss lessons learned.
- Update this playbook or create a new one if the threat becomes recurring.

Appendix F – Forms Templates

- **Customer Notification Email Template**

Subject: Important Security Notice
Dear [Customer Name],

We recently identified a security incident that may have affected your account information. Our security team has taken immediate action to deal with the issue and is collaborating with authorities and cybersecurity specialists to ensure your data remains protected.

We will provide further updates as our investigation progresses.
Thank you for your understanding,

Corporate Communications Officer

- **Media Statement**

  Cyber Tree Systems has detected a cybersecurity incident affecting certain systems. Immediate containment measures were implemented, and our investigation is ongoing. Currently, there is no evidence of data misuse. We will continue to provide updates as more information becomes available.

  - **Internal Staff Update**

    The Information Security team has identified a potential security event. Please refrain from discussing the incident externally or on social media. Direct any questions to the Corporate Communications Officer.